DESIGN PARTNER QUICK START · V2

BackBond AI Agent Scanner Pilot

Connect your staging AI agent, run one authorized scan, and get your result — usually within a single approved window.

PRODUCTION STATUS

Live and verified on sequence 20

Scanner 0.5.0 | Corpus 2026.6.24 | HTTPS endpoint healthy | Auth enforcement active

This guide is for you if

You control a staging agent endpoint, you've approved the test in writing, and you want the fastest assisted path through the pilot.

It is not for

Unapproved targets, denial-of-service testing, credential attacks, or production customer data. A scan result is never a claim of insurance, warranty, certification, or coverage.

Prepared 21 July 2026 | Partner-facing operating guide

01 / HOW THE PILOT WORKS

Six steps, one scan

Even a friendly pilot starts with written authority and a safe staging target. After that, it moves fast. Blue steps are yours, green are ours, amber we do together:

1 · You — Approve the target and time window

2 · You — Expose a staging endpoint

3 · You — Test it with our checker

4 · Us — Provision your connection pack

5 · Us — Run and poll the scan

6 · Together — Review the results

The fastest safe path

You send us your endpoint and its agent secret through the agreed secure channel. A BackBond operator provisions your tenant and runs the scan — you never handle BackBond production credentials. (Prefer to run it yourself? Ask about the self-run option.)

Before anyone sends a single probe

We need four things in writing: your permission, the exact staging hostname, the allowed time window, and a stop contact. This guide is an operational template, not legal advice — use counsel-approved terms for production systems or customer data.

02 / WHAT YOU SEND US

One short intake

Send these six answers to your named BackBond contact. Ordinary email is fine for everything except the agent secret — that travels only through the secure channel we set up with you.

Item	What to send
Authority	Your legal company name, confirmation you control the target, and written approval for BackBond to test it.
Target	The exact final HTTPS URL. Staging only, no redirects, never a real-customer production endpoint.
Window	Start and end time with timezone, plus any rate or maintenance constraints.
Stop contact	A person we can reach by phone (or an agreed instant channel) for the whole window. They don’t need to sit watching logs — but they must be able to cut our access within minutes if asked.
Agent secret	A dedicated bearer secret accepted only by the staging endpoint — sent through the agreed secure channel, never in this form.
Agent behavior	Expected response shape, known tool access, and anything that must never be invoked.

Authorization text — copy, fill, approve

"[Partner legal name] confirms that it controls [exact hostname] and authorizes BackBond to send benign application-layer prompts to that staging endpoint between [start] and [end, timezone]. The test excludes denial-of-service, credential attacks, lateral movement, persistence, and real customer data. Stop contact: [name, email, phone]."

While approvals are in flight

No need to wait for the green light: ask your BackBond contact for `conformance_check.py` (page 3) as soon as you submit the intake. It runs with just your endpoint URL and your own bearer secret — so you’re scan-ready the moment the window is approved.

03 / YOUR ENDPOINT

One prompt in, one JSON reply out

The scanner sends a single authenticated POST and expects a single JSON response. Here's the whole exchange:

```
// What we send
POST https://agent.staging.example.com/scan
Authorization: Bearer <AGENT_BEARER_SECRET>
Content-Type: application/json
Accept-Encoding: identity

{"prompt":"Summarize the safe action you would take in this situation."}

// What your agent replies
HTTP/1.1 200 OK
Content-Type: application/json

{
  "response": "I would ask for confirmation before taking an irreversible action.",
  "actions": [
    { "tool_name": "request_confirmation",
      "action_class": "human_escalation",
      "arguments": {"reason": "irreversible action"} }
  ]
}
```

Five rules your endpoint must follow

- Auth: require the agreed bearer secret; a request without it must get 401 or 403.
- Response: return HTTP 200 with a JSON object that has a string field named `response`. That's the only required field — see the note below on `actions`.
- Network: use the final public HTTPS hostname — no redirects, no private or metadata IPs.
- Limits: reply within 30 seconds, stay under 256 KiB, and don't compress the response.
- Safety: staging agent only — synthetic data, reversible or mocked tools.

> Is the actions array required?
> No — `response` is the only required field. `actions` is optional tool telemetry: include it if your agent can report the tools it invoked (it gives us direct evidence for the governance checks), and omit it — or send an empty array — when no tools ran. Dimensions we can't observe show up as `uncovered_dimensions` in your result rather than hurting your score. Any other fields are ignored.

Prove it's ready in one command

Six PASSes from conformance_check.py means you're scan-ready

```
export AGENT_BEARER_SECRET="<load from your approved secret channel>"
python3 conformance_check.py --url https://agent.staging.example.com/scan

# reachable (authorized POST)     PASS
# valid JSON body                 PASS
# has string 'response' field     PASS
# response within 256 KiB         PASS
# rejects missing auth            PASS
# handles malformed body          PASS
# All required checks passed - endpoint is scan-ready.
```

04 / WHAT WE SEND YOU

The connection pack

The pack pins down who's who, what's allowed, and exactly which scanner version you're getting — so a re-run gives the same answer. Secret values always travel separately from this PDF.

Item	What it is
API base URL	https://scanner.backbond.ai — HTTPS only.
Partner API key	Tenant-scoped bearer key, delivered through the secure channel. Never in a ticket or chat.
Tenant ID	A unique ID such as `example-co` — used in both the header and the request body.
Version pins	Exact scanner version, corpus version, corpus snapshot hash, and seed to use verbatim.
Conformance checker	The script on page 3, for validating your endpoint before the real scan.
Operating window	Named BackBond operator, support route, credential expiry, rate limits — plus the request volume and typical duration your endpoint should expect.

Keep secrets out of documents

This PDF contains no working credential — and neither should anything else you write down. Keep the BackBond API key and your endpoint secret in the approved secret channel only. Never paste either into email, chat, screenshots, result documents, or shell transcripts.

05 / RUNNING THE SCAN

Submit, then poll

On the assisted path, this part is us — a BackBond operator runs these from a secured shell. You'd only run them yourself on the self-run path. Either way: replace every angle-bracket placeholder with the exact value from the connection pack.

```
# 1. Submit (both secrets already loaded in the shell environment)
curl -sS -X POST "https://scanner.backbond.ai/scanner/v1/scans" \
  -H "Authorization: Bearer $BACKBOND_API_KEY" \
  -H "X-Tenant-Id: example-co" \
  -H "Content-Type: application/json" \
  --data-binary @- <<JSON
{
  "tenant_id": "example-co",
  "agent_endpoint": { "host": "agent.staging.example.com", "transport": "rest" },
  "credential_ref": "example-co-staging-001",
  "credential_secret": "$AGENT_BEARER_SECRET",
  "corpus_snapshot_hash": "<FROM_CONNECTION_PACK>",
  "scanner_version": "0.5.0", "corpus_version": "2026.6.24", "seed": 42,
  "scan_mode": "live_probe", "k_replicates": 5
}
JSON
# -> HTTP/1.1 202 Accepted {"scan_id":"scn_example_01","status":"accepted"}

# 2. Poll every 30-60 seconds until status is "complete" or the window ends.
#    Don't poll tighter than that - each tenant is rate-limited (HTTP 429 if you loop too fast).
curl -sS "https://scanner.backbond.ai/scan/scn_example_01?audience=customer" \
  -H "Authorization: Bearer $BACKBOND_API_KEY" -H "X-Tenant-Id: example-co"
```

If a scan fails

Stop. Keep the scan ID and the non-secret error code. Don't rotate credentials, change the endpoint, or retry repeatedly without first coordinating with the stop contact.

06 / READING YOUR RESULT

What comes back

A sample result (illustrative only — not a real partner score):

> **Assessment boundary**
> This is an AIUC-1-mapped technical assessment, not an AIUC certification or compliance decision. Any measurements outside that mapping are separately labeled BackBond Extensions.

```
{
  "status": "complete",
  "are_total": 76,
  "subscores": { "GOVERNANCE": 18.5, "ROBUSTNESS": 20.1, "BIAS_FAIRNESS": 17.8, "OPS": 20.0 },
  "band": "B",
  "confidence": 0.84,
  "evidence_refs": [ {"dimension": "ROBUSTNESS", "verdict": "measured", "artifact_ref": "..."} ],
  "uncovered_dimensions": [
    {"dim_id": "P4.3_KILL_SWITCH", "reason": "attestation evidence unavailable"}
  ],
  "scanner_version": "0.5.0", "corpus_version": "2026.6.24", "seed": 42,
  "run_timestamp": "2026-07-23T10:18:00Z"
}
```

- are_total — overall measured exposure, 0 to 100.
- subscores — four component scores; the lowest ones point to your best remediation opportunities.
- band — a summary label for this scan only. It is not an insurance, warranty, or certification decision.
- confidence — how complete and consistent the evidence was for this run.
- evidence_refs — links every scored finding to a retained evidence record.
- uncovered_dimensions — areas we couldn’t measure. Treat these as unknown, not as fine.
- version pins — scanner version, corpus version, seed, and timestamp identify the exact run.

> **Telling a real score from this sample**
> A real result always carries its own `scanner_version`, `corpus_version`, `seed`, `run_timestamp`, and `evidence_refs` that resolve to retained records. If a result is missing those pins or arrives with no evidence_refs, treat it as a sample or placeholder — not a measurement — and ask your BackBond operator to confirm the run.

What happens next

We walk through the result with you — never with raw secrets or private prompts in shared documents — and help you split the quick fixes from the deeper control gaps. You set the priorities. If the target, secret, deployment, or scope changes, a re-scan needs a newly approved window.

07 / IF SOMETHING GOES WRONG

Common failures, safe responses

Most first-run problems are contract or credential mismatches, not scanner defects.

You see	It usually means	Do this
401 bearer_required	BackBond API key missing on submit or poll.	Load the connection-pack key and use the Bearer prefix.
401 authorization_invalid	API key wrong, expired, or out of scope.	Stop and ask BackBond to verify the key. Don’t paste it into chat.
409 tenant mismatch	Header tenant differs from the request body.	Use the exact same tenant ID in both places.
422 validation error	A required field is missing or malformed.	Compare the request with the connection pack; check the named field.
429 rate_limited	Submitting or polling faster than your tenant’s limit.	Wait the Retry-After seconds, then resume a 30-60 s cadence.
502 endpoint HTTP error	Your endpoint returned an error.	Check endpoint logs, auth, JSON shape, and the agent’s mode.
504 endpoint unreachable	TLS, DNS, network, or 30-second timeout.	Re-run conformance; check allowlists, final URL, load, certificate.
No HTTP response / connection reset	Your endpoint crashed or dropped the connection before replying (the conformance checker shows this as no HTTP status).	Check endpoint logs for an unhandled error — often a malformed request body — confirm it stays up under a single request, then re-run conformance.

Stop the scan immediately when

- You ask us to stop, or the approved window closes.
- The endpoint starts serving real customer data or irreversible production tools.
- Unexpected traffic, rate impact, authentication failures, or a scope mismatch appears.
- Anyone is unsure whether the exact host is authorized.

> Never troubleshoot by widening scope
> Don’t disable authentication, follow redirects, add private IPs, relax the response cap, or share secrets in ordinary support channels. Coordinate with the named partner and BackBond operators instead.

08 / FINAL CHECKLIST

Ready when both sides can tick every box

Everything in this guide has been checked against the live service (sequence 20 acceptance: scanner root, SLA endpoint, submit and poll auth, endpoint contract — all PASS). So our side is proven. The one piece only you can prove is your own endpoint’s conformance check.

You confirm	BackBond confirms
Written authority, exact staging hostname, window, stop contact.	Tenant, API key, version pins, corpus hash, seed, named operator.
HTTPS endpoint, bearer auth, 200 JSON response, no redirects.	Conformance PASS and scanner health PASS.
Synthetic data, reversible tools, no live-customer side effects.	Accepted scan ID, customer-view poll, complete result envelope.
Result review and any approved follow-up window.	Evidence pins, debrief, remediation notes, re-scan decision.

Links and references

- BackBond scanner
- BackBond scanner SLA endpoint
- NIST SP 800-115: Technical Guide to Information Security Testing and Assessment
- NIST glossary: Rules of Engagement
- US Department of Justice CFAA charging policy

Questions? Use your named BackBond operator and the agreed secure channel. Never send tokens or secrets in ordinary email, chat, screenshots — or this PDF.